FarmaExpres

Historia de Usuario HU-RF-03
Cambio de Contraseña

Versión: 1.0
Fecha: 03/03/2026

Documento de especificación funcional y evidencias de aceptación.

1. Identificación

Código	HU-RF-03
Nombre	Cambio de Contraseña
Área	Seguridad y Gestión de Usuarios
Actor principal	Administrador
Prioridad	Must Have
Descripción corta	Permite que un Administrador cambie (restablezca) la contraseña de un usuario de forma segura.

2. Historia de usuario

Como Administrador**, quiero** cambiar la contraseña de un usuario **para** restablecer su acceso y mantener la seguridad del sistema, registrando la acción en la bitácora.

3. Alcance

Esta historia cubre el proceso de cambio/restablecimiento de contraseña ejecutado por un Administrador. Incluye validación de identidad, registro de la nueva contraseña y persistencia segura (cifrada/hasheada), además del registro obligatorio en bitácora.

4. Precondiciones

- Existe al menos un usuario con rol Administrador autenticado (sesión/token válido).
- El usuario objetivo existe en el sistema y se conoce su identificador (Id).
- La bitácora de seguridad se encuentra habilitada.

5. Reglas de negocio y seguridad

Regla	Descripción
RN-01	El sistema debe solicitar validación de identidad antes de permitir el cambio de contraseña (re-autenticación o confirmación de sesión).
RN-02	Solo un usuario con rol Administrador puede cambiar la contraseña de otro usuario.

RN-03	El sistema debe permitir registrar una nueva contraseña para el usuario objetivo.
RN-04	La contraseña debe almacenarse cifrada/hasheada en la base de datos (no en texto plano).
RN-05	El sistema debe registrar en la bitácora la acción de cambio de contraseña (quién, a quién, cuándo y resultado).

6. Flujo principal

1. El Administrador ingresa al módulo de gestión de usuarios.
2. Selecciona al usuario objetivo e ingresa/valida el Id del usuario.
3. El sistema solicita validación de identidad del Administrador.
4. El Administrador registra la nueva contraseña (y confirmación si aplica).
5. El sistema valida los campos (obligatorios, coincidencia y política de seguridad definida).
6. El sistema guarda la contraseña cifrada/hasheada en la base de datos.
7. El sistema registra la acción en bitácora y muestra confirmación de éxito.

7. Flujos alternos y errores

Código	Escenario	Resultado esperado
FA-01	Id de usuario inexistente	El sistema rechaza la solicitud e informa que el usuario no existe.
FA-02	Usuario sin permisos (no Admin)	El sistema bloquea la operación y devuelve un error de autorización.
FA-03	Contraseña inválida o no coincide	El sistema solicita corregir la contraseña y no realiza cambios.
FA-04	Fallo al persistir en base de datos	El sistema informa error y registra el intento en bitácora.

8. Criterios de aceptación

☐ CA-01. Solicita validación de identidad antes de cambiar contraseña.

☐ CA-02. Solo el Administrador puede cambiar la contraseña de un usuario (requiere Id del usuario).
☐ CA-03. Permite registrar una nueva contraseña para el usuario objetivo.
☐ CA-04. Al almacenar, la contraseña queda cifrada/hasheada en la base de datos.
☐ CA-05. Registra la acción en bitácora (éxito o fallo).

9. Evidencias de prueba

• Captura o registro de la validación de identidad (por ejemplo: confirmación de sesión/token).
• Registro en bitácora del evento de cambio de contraseña.
• Consulta en base de datos mostrando que la contraseña no está en texto plano (permanece cifrada/hasheada).

Comentario: Cambio de contraseña ejecutado por un administrador indicando el ID del usuario. El sistema confirma la actualización con respuesta 200 OK.

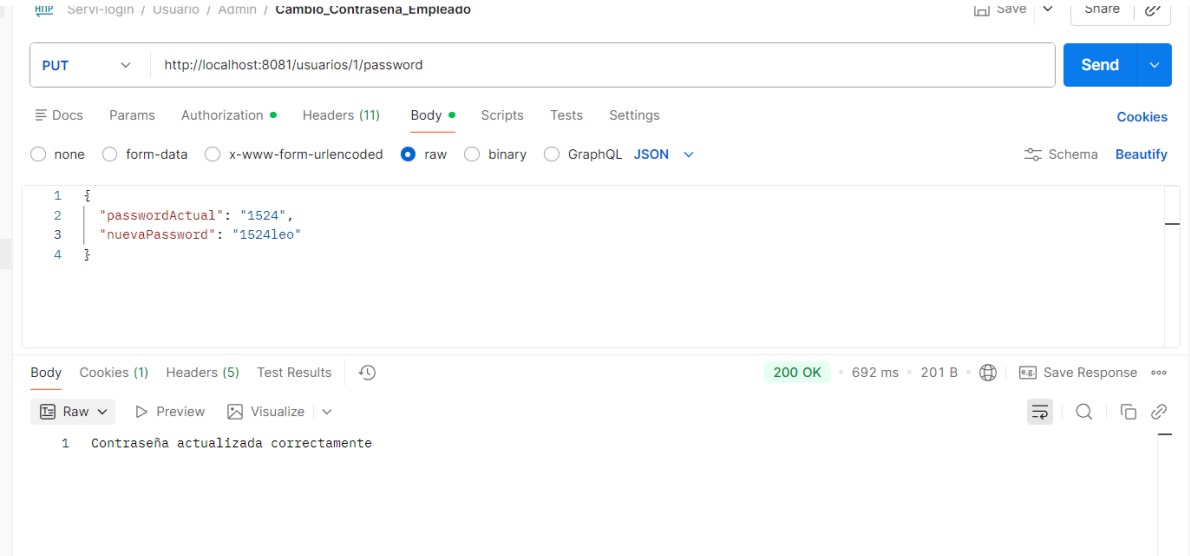

Figura 1. Endpoint de cambio de contraseña (respuesta exitosa).

Comentario: Verificación de seguridad: en la base de datos la contraseña no se almacena en texto plano; permanece hasheada/cifrada (ej. prefijo $2a$ típico de bcrypt).

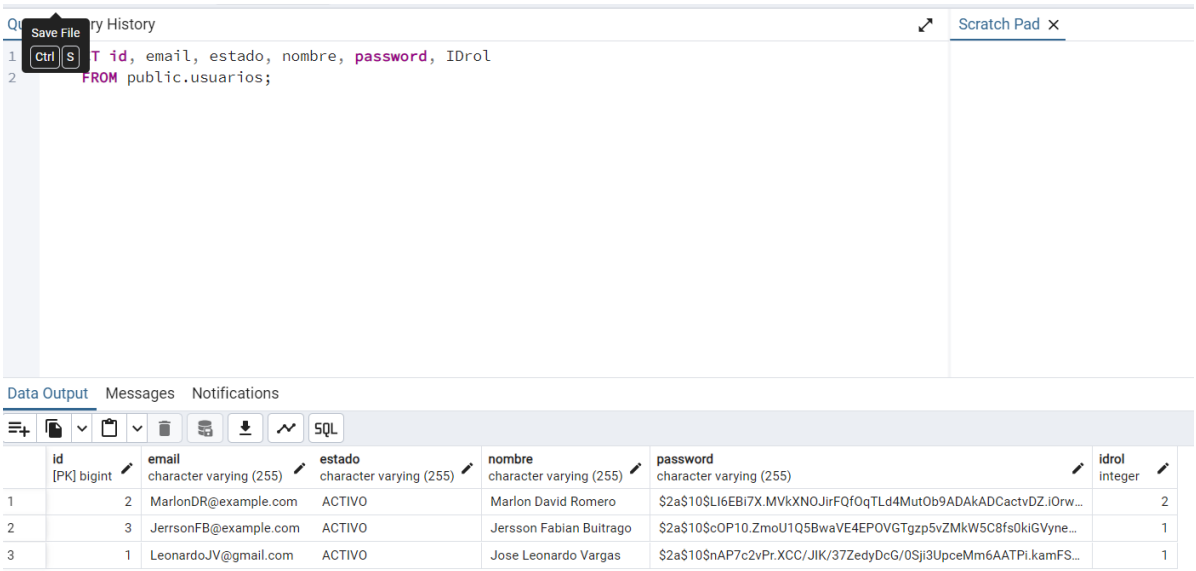

Figura 2. Contraseña almacenada de forma segura (hash en base de datos).

Comentario: Auditoría: la acción de cambio de contraseña queda registrada en bitácora, permitiendo trazabilidad y control.

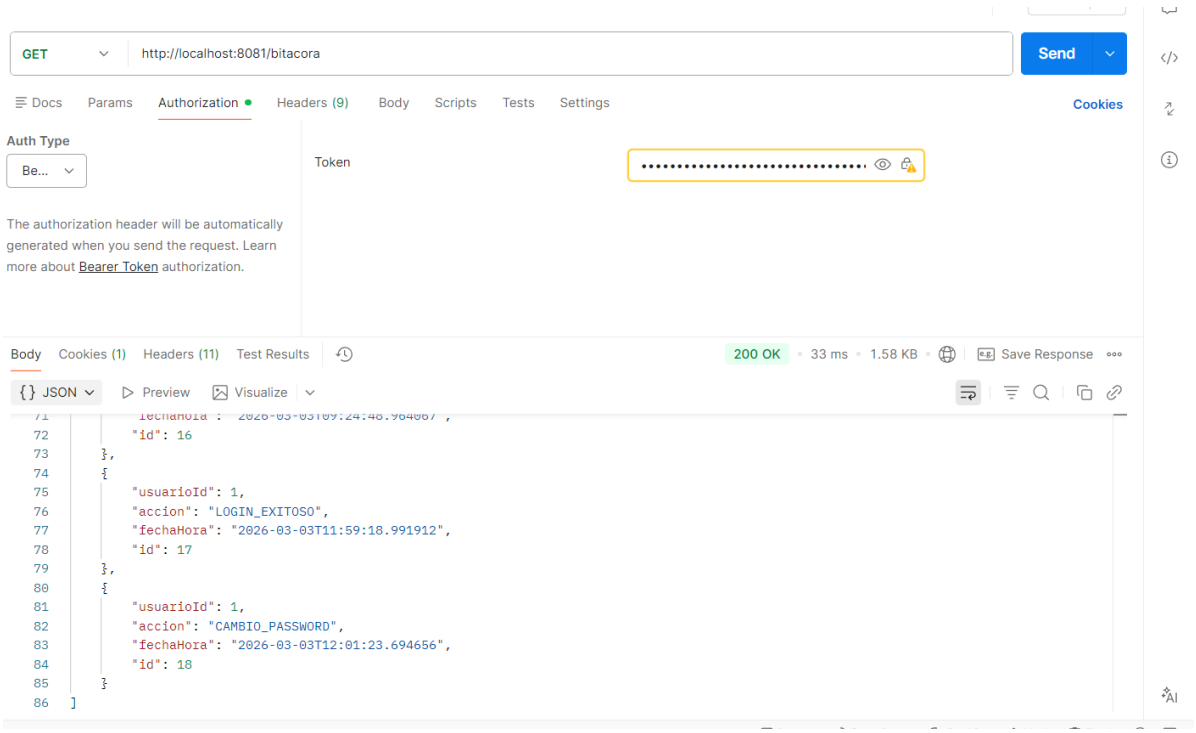

Figura 3. Registro en bitácora del cambio de contraseña.

10. Casos de prueba

CP	Entrada/Condición	Pasos	Resultado esperado
CP-01	Admin autenticado + Id válido + contraseña válida	1) Seleccionar usuario 2) Validar identidad 3) Registrar nueva contraseña 4) Confirmar	Contraseña actualizada (cifrada) y evento en bitácora.
CP-02	No Admin intenta cambiar contraseña	1) Intentar cambio de contraseña	Operación rechazada por permisos y evento registrado en bitácora.
CP-03	Id inexistente	1) Ingresar Id no existente 2) Intentar cambio	Sistema informa que el usuario no existe; no hay cambios.

Anexo A. Checklist original

Los siguientes puntos fueron tomados del documento base y se mantienen como verificaciones mínimas:

☐ Solicita validación de identidad.

☐ Solicita el Id del usuario y solo el Admin puede cambiar contraseña.

☐ Permitir registrar nueva contraseña.

☐ Almacena contraseña cifrada (verificable en base de datos).

☐ Registra acción en bitácora.